EL SOBRE DE LAS OCHO

Qué vas a construir

Un portal local que guarda un parcial ficticio y decide si puede entregarlo. Tú manejas dos cuentas en sesiones separadas del mismo navegador. El profesor observa la demostración.

Objetivo verificable

A las 7:59 el estudiante identificado debe recibir un rechazo. A las 8:00 debe recibir el original. Si a esa misma hora se sustituye el archivo por una copia modificada, debe bloquearse la entrega y quedar registrado el motivo.

Requisitos de la aplicación

CAPACIDAD	CONDICIÓN DE ACEPTACIÓN
Publicar	La cuenta docente entra con contraseña y segundo factor local. Puede publicar un archivo de texto ficticio, asignarlo al estudiante y fijar su apertura a las 08:00 de una fecha del laboratorio en hora de Bogotá.
Abrir	El estudiante inicia su propia sesión. El servidor comprueba cuenta, asignación y hora en cada descarga, incluida la petición hecha directamente por URL.
Proteger	Al publicar se cifra el archivo y se guarda una huella de referencia. El portal solo entrega el documento completo después de comprobar la integridad.
Registrar	Cada decisión deja hora, cuenta de prueba, acción y motivo. Los registros omiten contraseñas, códigos, claves y contenido del parcial.
Repetir	Un control local permite adelantar el reloj didáctico, seleccionar la copia de ensayo y volver al estado inicial. Solo tú lo manejas desde el portátil.
Demostrar	Puedes exportar capturas y registros de tus propias ejecuciones. Cada evidencia indica la clase, el entorno, el resultado esperado y el observado.

Límites del trabajo

Incluye un portátil, dos cuentas ficticias, un parcial activo, una aplicación, una maqueta de red y una copia vulnerable aislada para la práctica. Se usan herramientas gratuitas o de uso educativo, descargadas antes de presentar.

Quedan fuera la calificación de exámenes, los datos de estudiantes reales, el despliegue público, el uso de la red universitaria y un centro de operaciones profesional. Las pruebas de tráfico se dirigen solo a servicios propios.

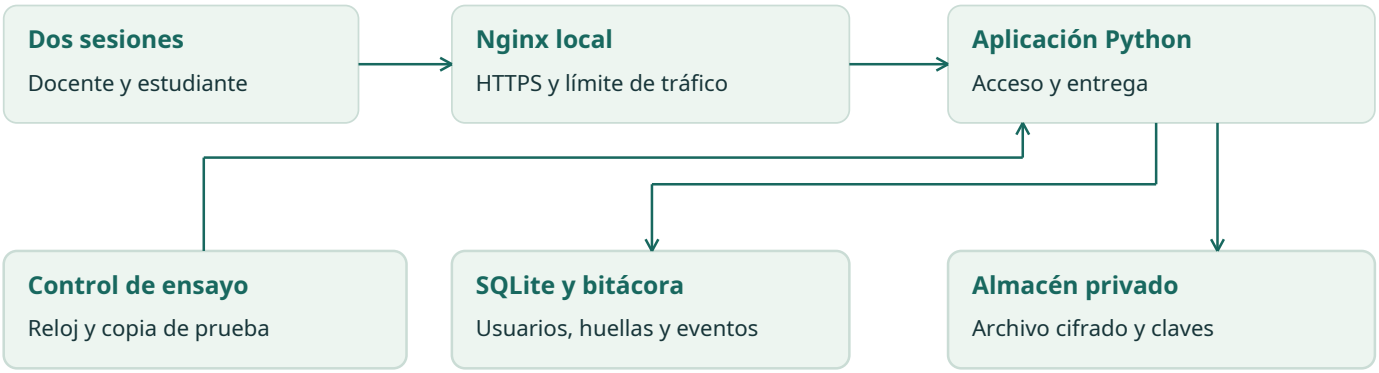
Qué verás en pantalla

La vista docente permite publicar y revisar la bitácora. La vista estudiante muestra el botón de descarga y la respuesta del servidor. En una terminal separada manejas los controles del ensayo. Las dos cuentas corresponden al mismo presentador.

EL SOBRE DE LAS OCHO

Cómo encajan las piezas

La aplicación real tiene dos servicios en Docker Compose. Nginx es la puerta de entrada. La aplicación Python toma las decisiones. Los archivos y los registros permanecen dentro del portátil.



COMPONENTE	RESPONSABILIDAD Y CLASE
Navegador	Una ventana normal y una privada mantienen las sesiones separadas. La web se abre solo en el propio equipo. Identidad y acceso, clase 4.
Nginx	Único puerto de la aplicación publicado en la dirección local 127.0.0.1. Termina HTTPS, añade cabeceras y aplica cuotas. Clases 2, 5 y 10.
Aplicación Python	Comprueba credenciales, rol, asignación, hora e integridad. Atiende las descargas y escribe el motivo de cada decisión. Clases 1, 4 y 8.
SQLite y archivos	SQLite guarda cuentas, metadatos y bitácora. Un volumen privado guarda el parcial cifrado. Las cuentas web no pueden escribir la huella aprobada ni acceder al directorio. Clases 1, 4 y 5.
Controles locales	Una utilidad de ensayo ajusta la hora de apertura y prepara la copia alterada. La maqueta de Packet Tracer y el modelo NAC en Python representan la red por separado. Clases 3, 4 y 6.
Herramientas de evidencia	Wireshark observa el tráfico. Git, Bandit y Trivy revisan cambios, código e imágenes. Nmap/NSE examina el objetivo autorizado y ApacheBench genera carga local. Clases 2 y 7–10.

La copia con fallo SQL tiene datos de prueba y almacenamiento propios. Se activa solo para el ejercicio. Las claves, cuentas y volúmenes del portal protegido quedan fuera de esa copia.

Por qué funciona en un solo computador

El navegador habla con Nginx por HTTPS. Python recibe la solicitud por la red privada de los contenedores, consulta los datos y devuelve la decisión. SQLite se usa dentro de Python. Packet Tracer abre su propia maqueta en el mismo equipo.

EL SOBRE DE LAS OCHO

Reglas de entrega

Estos criterios explican cómo responde el sistema aunque alguien se salte los botones del navegador o cambie la hora de Windows.

Qué decide el servidor en cada solicitud

CONDICIÓN, EN ESTE ORDEN	RESPUESTA	QUÉ OCURRE
Cuota por IP excedida en Nginx	429	Nginx rechaza antes de la aplicación. La respuesta queda en el registro de Nginx.
Sin sesión válida	401	Pide iniciar sesión. No lee ni devuelve el parcial.
Rol o asignación incorrectos	403	Bloquea publicar como estudiante o descargar un parcial ajeno.
Antes de la apertura	403	Registra «fuera de horario». No envía bytes del archivo.
Apertura cumplida, archivo alterado	409	Registra un fallo de integridad y bloquea la entrega completa.
Apertura cumplida, original íntegro	200	Entrega el original y registra el acceso permitido.

Tres decisiones que tendrás que defender

1. Un reloj solo para el parcial

La apertura usa la fecha y hora del servidor del laboratorio. Se permite desde las 08:00 inclusive. Adelantar este reloj no cambia la hora de Windows, las sesiones ni el autenticador del docente.

2. Una referencia protegida

Al publicar se calcula SHA-256 de los bytes originales. Se cifra el archivo con AES y se protege su clave con la clave pública RSA del servicio. El proceso de descarga usa la clave privada y compara la huella de los bytes recuperados antes de enviarlos. Un error de descifrado también impide la entrega.

3. Una copia alterada reproducible

La utilidad local prepara una segunda copia con una letra distinta y la cifra de forma válida, sin modificar la huella original. Así se observa qué detectó SHA-256. Restaurar el original permite repetir el mismo caso.

Extras de implementación

SQLite almacena los datos. Un autenticador local TOTP con secreto independiente sirve como segundo factor didáctico. Bandit revisa Python. Se usará una biblioteca criptográfica para AES-GCM y RSA-OAEP. Estas variantes y la biblioteca son decisiones de implementación. OpenSSL permite preparar las claves y el certificado de HTTPS del laboratorio.

Las contraseñas se verifican con una función de derivación y sal por cuenta. La clave privada y el secreto del autenticador se guardan fuera del repositorio. El navegador no debe conservar en caché las descargas de la demo. Si falta el archivo o su referencia, la aplicación bloquea la entrega y registra el error.

EL SOBRE DE LAS OCHO

Cobertura del semestre

Cada fila indica qué podrás mostrar y dónde estará la evidencia. Las referencias son páginas de los PDF originales. Las observaciones de la práctica se completarán durante la construcción.

CLASE Y FUENTE	EVIDENCIA PREVISTA	QUÉ EXPLICARÁS
1 · Criptografía pp. 7–14	Archivo cifrado, clave protegida y dos huellas distintas tras editar una letra.	AES, RSA y hash. Comparación con ofuscación y con el ejercicio MD5.
2 · Tráfico pp. 3–20	Capturas de la misma marca ficticia en HTTP y HTTPS. Identificar IP, puerto, inicio TCP y contenido visible.	OSI, TCP/IP, DPI y filtrado. Dibujar la VPN docente y sus extremos.
3 · WiFi y VLAN pp. 4–14	Packet Tracer: WiFi WPA2, puertos de acceso, troncal y ping permitido o bloqueado según zona.	VLAN 10 docentes, 20 servidores, 30 alumnado. Comparar WEP/WPA/WPA2/WPA3.
4 · Identidad pp. 2–15	Cambio de cuenta, MFA docente, registro del intento. En la maqueta, acceso válido e inválido al switch con RADIUS.	AAA, RBAC, ABAC, sal, mínimo privilegio y Zero Trust. TACACS+ como referencia.
5 · Bastionado pp. 3–16	Cabeceras X-Frame-Options y X-Content-Type-Options. Verificar que Nginx oculta el número de versión.	OWASP A05:2021, banners, clickjacking y MIME-sniffing.
6 · NAC pp. 4–18	Modelo Python de estado, zonas, reglas heredadas y denegación por defecto. Mostrar acceso interno y bloqueo externo.	NAC, cortafuegos con o sin estado, DMZ y filtrado por puerto o aplicación.
7 · DevSecOps pp. 4–22	Flujo local en Git: comprobar código e imagen, detener la promoción ante un hallazgo y guardar el informe posterior.	CI/CD, SAST, SCA, CVE y configuración versionada. Nube y responsabilidad compartida en el esquema.
8 · Pentesting pp. 4–21	Informe de Nmap/NSE y prueba manual SQL en la copia vulnerable. Repetir con la consulta parametrizada.	Reconocimiento, escaneo, análisis, explotación controlada y reporte. Ejemplo de falso negativo.
9 · Disponibilidad pp. 4–16	Ráfaga HTTP acotada y registro de latencia y CPU. Simular dos tablas ARP para mostrar el posible desvío.	Tríada CID, DoS/DDoS, botnets, MITM y diferencias entre capas de red.
10 · Defensa pp. 4–18	Repetir carga con cuota y cliente legítimo. Seguir un CVE corregible antes y después de parchear una imagen.	Controles preventivos, detectivos y correctivos. WAF e IDS/IPS como ejemplos de clase.

Solo anunciados o sin taller específico. Situar Metasploit en la fase de explotación, explicar HSTS junto a TLS y mencionar el NAC avanzado. Para la semana 11 se propone una ficha de incidente y revisión de controles como aproximación al SOC y al cumplimiento. La semana 12 corresponde a la validación final. La malla no aporta una norma ni una rúbrica detallada.

EL SOBRE DE LAS OCHO

Plan de construcción

Cada etapa deja un resultado verificable. La estimación de 30–40 horas incluye preparación y ensayo. El informe extenso y las diapositivas se preparan en la fase 5.

ETAPA	TIEMPO	TRABAJO	CONDICIÓN PARA CERRARLA
1 · Preparar	3–4 h	Verificar el entorno en el portátil, las herramientas disponibles y el espacio para imágenes. Levantar el portal mínimo en la dirección local.	La página abre después de reiniciar los servicios y solo expone la entrada prevista.
2 · Identificar	5–7 h	Crear las dos cuentas, sesiones separadas, MFA docente, roles y reloj del laboratorio.	Distinguir los rechazos por sesión, rol y horario. Pasar del rechazo a la aceptación a las 8:00.
3 · Sellar	5–6 h	Cifrar el parcial, proteger su clave, registrar la huella y preparar las dos copias de ensayo.	El original se recupera idéntico. La copia modificada se bloquea. Al restaurarlo vuelve a funcionar.
4 · Proteger la red	5–7 h	Activar TLS y cabeceras. Preparar la maqueta VLAN/RADIUS y el modelo NAC. Guardar capturas de tráfico.	Distinguir HTTP de HTTPS y explicar un acceso de red permitido y otro denegado.
5 · Auditar y corregir	7–9 h	Preparar la copia SQL aislada, el análisis estático y el escaneo de imagen. Aplicar un parche y la cuota por IP.	El intento SQL deja de funcionar tras el arreglo. Quedan informes de las dos versiones y la prueba de carga.
6 · Repetir y sustentar	5–7 h	Ejecutar los casos del plan, restaurar el estado inicial y ensayar solo. Completar una ficha por clase.	Repetir la demo desde las 7:59 dos veces y asociar cada evidencia con su tema.

Checklist personal

- ☐ Puedo entrar con cada cuenta y distinguir qué permisos tiene.
- ☐ Puedo restaurar el original, la hora y los datos de prueba sin ayuda.
- ☐ Cada evidencia tiene clase, condición inicial, resultado esperado y resultado observado.
- ☐ Las pruebas activas usan solo el laboratorio propio. Las simulaciones están identificadas.

Ritmo de la fase 4

Al empezar la construcción trabajaremos un paso cada vez. Tú lo ejecutarás en tu computador, comprobarás el resultado y confirmarás antes de continuar.

EL SOBRE DE LAS OCHO

Qué debe pasar en las pruebas

Los resultados de estas dos páginas son criterios de aceptación. Una captura de un resultado distinto también se conserva para poder explicar y corregir el fallo.

CASO	QUÉ HACES TÚ	RESULTADO ESPERADO Y EVIDENCIA
P1 · Identidad	Abre una sesión sin identificar y solicita el archivo. Intenta publicar con la cuenta estudiante. Prueba el acceso docente con un segundo factor incorrecto y luego válido.	La descarga sin sesión recibe 401, la publicación del estudiante recibe 403 y el docente solo accede tras el segundo factor válido. Guardar decisiones sin mostrar secretos.
P2 · Hora límite	En la misma fecha de prueba pide el mismo original a las 07:59:59 y a las 08:00:00, sin tocar el reloj de Windows.	Primero 403 sin archivo. Después 200 con los bytes originales. En la bitácora solo cambia la condición de hora.
P3 · Integridad	A las 08:00 sustituye el archivo por la copia modificada y cifrada. Repite desde la misma cuenta. Restaura después el original.	La huella de la copia difiere, se devuelve 409 y no se envía el documento. Con el original restaurado vuelve el 200.
P4 · Tráfico	Usa un archivo con una marca ficticia en el servicio de ensayo HTTP. Repite la consulta por HTTPS en la aplicación.	Wireshark reconstruye la marca en la petición o respuesta HTTP. En la captura HTTPS sin claves de sesión se observa tráfico cifrado. Guardar ambos flujos e identificar el inicio TCP.
P5 · Red e identidad	En Packet Tracer, prueba conectividad antes y después de separar las VLAN. Usa RADIUS para el acceso al switch. En Python, cambia el estado de un equipo docente a no verificado.	La política deja pasar el tráfico permitido, bloquea administración desde alumnos y rechaza la identidad o el estado no autorizados. Guardar la maqueta y la salida del simulador por separado.
P6 · Configuración web	Inspecciona las cabeceras de una respuesta y trata de incrustar el portal desde otro origen local de ensayo.	Se observan SAMEORIGIN y nosniff y el número de versión no aparece en el banner. La incrustación desde el otro origen queda bloqueada.

Una evidencia útil

Ejemplo de ficha. Clase 4, cuenta estudiante, reloj 07:59:59, original intacto. Se espera una descarga denegada. Durante la construcción anotarás el código observado, la línea de bitácora y el nombre de la captura.

EL SOBRE DE LAS OCHO

Ataques simulados y demostración

Las pruebas ofensivas tienen un objetivo local con datos de ensayo. Para la exposición seleccionarás los resultados que mejor expliquen cada decisión.

CASO	QUÉ HACES TÚ	RESULTADO ESPERADO Y EVIDENCIA
P7 · Inyección SQL	Escanea solo la copia de laboratorio con Nmap/NSE. Reproduce el acceso indebido en el formulario vulnerable y repite tras parametrizar la consulta.	El caso vulnerable permite el acceso indebido. El corregido deniega ese intento y acepta una credencial válida. Un puerto abierto, por sí solo, no demuestra una inyección.
P8 · Análisis y parche	Escoge un CVE de una dependencia o imagen de ensayo con corrección disponible. Revisa código con Bandit y componentes con Trivy. Escanea antes y después con la misma base de vulnerabilidades.	La versión que supera el umbral alto o crítico se bloquea. Verifica qué ocurrió con ese CVE al actualizar. Solo se promueve la versión si pasa todos los controles del flujo.
P9 · Ráfaga local	Desde un cliente Docker envía hasta 100 peticiones, con concurrencia 5 y sesión de ensayo válida. Otro cliente autenticado con IP distinta pide el original. Repite con la misma carga, cuota de 5 peticiones por segundo por IP y margen de ráfaga de 5.	Registrar latencia del cliente normal, CPU y códigos antes y después. Con cuota se espera algún 429 para el exceso y 200 para el alumno autorizado. Verificar las IP vistas por Nginx. El porcentaje de rechazos se mide.
P10 · Intercepción y reinicio	Dibuja la tabla ARP normal y otra que asocia la IP del router a la MAC del supuesto atacante. Luego restaura la copia y el reloj del portal y repite P2 y P3.	Señala a qué equipo se desviaría el tráfico en la simulación. Tras reiniciar el caso, las mismas condiciones vuelven a producir las mismas decisiones.

Recorrido individual de 6–8 minutos

0–1 min Presentas el problema y enseñas las dos sesiones que tú manejas en el navegador.

1–4 min Ejecutas en vivo la descarga antes de la hora, la entrega del original a las 8:00 y el rechazo de la copia alterada.

4–6 min Muestras una captura HTTP/HTTPS y una corrección repetida, por ejemplo la del acceso SQL. Señalas en la matriz qué clases demuestra cada evidencia.

6–8 min Muestras la respuesta ante la ráfaga, explicas el papel de la maqueta de red y cierras restaurando el original.

El diseño parte de los diez PDF del semestre, sintetizados en la fase 1, y de la ficha individual de El sobre de las ocho de la fase 2 (página 2).

Consultar el temario **Consultar la propuesta individual**